

ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN
KHOA KHOA HỌC VÀ KỸ THUẬT THÔNG TIN



BÀI TẬP BÀI 5 (BUỔI 8)
MÃ ĐỘC VÀ KỸ THUẬT PHÂN
TÍCH MÃ ĐỘC

Mã Môn: IE105
Tên Môn: Nhập Môn Đảm Bảo và An Ninh Thông Tin
Lớp: IE105.F22.LT.CNTT
Giảng Viên: ThS. Tô Nguyễn Nhật Quang
Sinh Viên: Đinh Xuân Sâm
Mã Sinh Viên: 25410291

Ngày 05 Tháng 05 Năm 2026

MÃ ĐỘC VÀ KỸ THUẬT PHÂN TÍCH MÃ ĐỘC

1. Nêu chức năng và cách sử dụng một số công cụ sau đây:
 1. Netstat
 2. Fport
 3. TCPView
 4. CurrPorts Tool
 5. Process Viewer
2. Liệt kê một số biện pháp phòng chống Trojan, Virus và Worm theo thứ tự ưu tiên từ cao đến thấp.
3. Tìm và nêu đặc điểm của 3 loại mã độc (1 Trojan, 1 Virus, 1 Worm...) xuất hiện trong thời gian gần đây (tên, nguồn gốc, đặc điểm, phương thức phá hoại, biện pháp phòng chống, nguồn tham khảo).

LỜI NÓI ĐẦU

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do.

LỜI CẢM ƠN

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do.

Giảng Viên

Mục Lục

Mục Lục	v
Danh Sách Bảng	vi
Danh Sách Hình Ảnh	vii
Danh Sách Mã Nguồn	viii
Bảng Viết Tắt	ix
1. Các Công Cụ Phổ Biến	1
1.1. Netstat	1
1.2. Fport	2
1.3. TCPView	3
1.4. CurrPorts Tool	5
1.5. Process Viewer (ay Process Explorer)	6
2. Các Biện Pháp Phòng Chống	8
2.1. Phòng Ngừa Ở Cấp Độ Người Dùng	8
2.2. Phòng Vệ Ở Cấp Độ Hệ Thống	8
2.3. Phòng Vệ Ở Cấp Độ Mạng	8
2.4. Phòng Vệ Ở Cấp Độ Dữ Liệu	8
3. 03 Loại Mã độc Tiêu Biểu Gần Đây	10
3.1. Trojan: Lumma Stealer (LummaC2)	10
3.2. Virus: Sality (Biến thể Đa hình 2024-2025)	11
3.3. Worm: Morris II (Sâu AI)	11
3.4. Phụ Lục: Giải Thích Thuật Ngữ Kỹ Thuật	12
A Thông Tin Về Báo Cáo Này	14
A.1 Mã Nguồn Báo Cáo	14
A.2 Mã Nguồn Nội Dung Chính	14
Tài Liệu Tham Khảo	15

DANH SÁCH BẢNG

DANH SÁCH HÌNH ẢNH

Hình ảnh 1	netstat -a	2
Hình ảnh 2	netstat -ano	2
Hình ảnh 3	TCPView	4
Hình ảnh 4	TCPView - Menu Ngữ Cảnh	5
Hình ảnh 5	CurrPorts Tool	6
Hình ảnh 6	Process Explorer	7

DANH SÁCH MÃ NGUỒN

BẢNG VIẾT TẮT

Viết Tắt	Nghĩa Đầy Đủ
API	Application Programming Interface
CNTT	Công Nghệ Thông Tin
CSDL	Cơ Sở Dữ Liệu
HTML	HyperText Markup Language
UI	User Interface
UX	User Experience

Bảng Viết Tắt

CHƯƠNG 1.

CÁC CÔNG CỤ PHỔ BIẾN

Trong quá trình phân tích và giám sát mã độc, việc theo dõi các tiến trình và kết nối mạng là cực kỳ quan trọng. Dưới đây là chức năng và cách sử dụng của 5 công cụ phổ biến.

1.1. Netstat

- Download: Không cần (tích hợp sẵn trong Windows/Linux/macOS).

1.1.1. Chức Năng

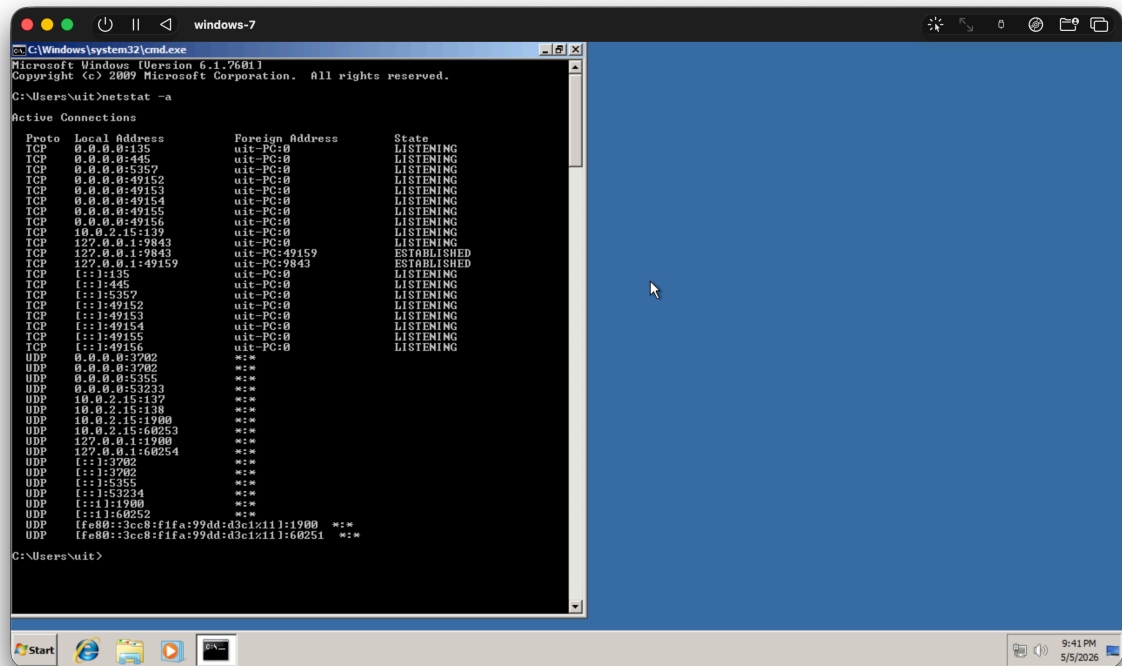
- Là một công cụ dòng lệnh (command-line).
- Tích hợp sẵn trên các Hệ Điều Hành (Windows, Linux, macOS).
- Giúp hiển thị các:
 - Kết nối mạng TCP/UDP đang hoạt động (ESTABLISHED).
 - Cổng đang lắng nghe (LISTEN).
 - Bảng định tuyến.
 - Các thống kê giao diện mạng.
 - PID của tiến trình tương ứng với kết nối đang có.

1.1.2. Cách Sử Dụng

- Mở Command Prompt (`cmd`) dưới quyền Quản Trị Viên (Administrator, Windows) hoặc root (Linux).
 - Mục đích có toàn quyền và xem được ứng dụng/kết nối từ toàn bộ người dùng.
- Gõ lệnh `netstat -a` để xem tất cả các kết nối.
- Gõ lệnh `netstat -ano` để hiển thị thêm cột PID (Process ID).
- Đối chiếu PID này với Task Manager để biết tiến trình nào đang kết nối ra ngoài.

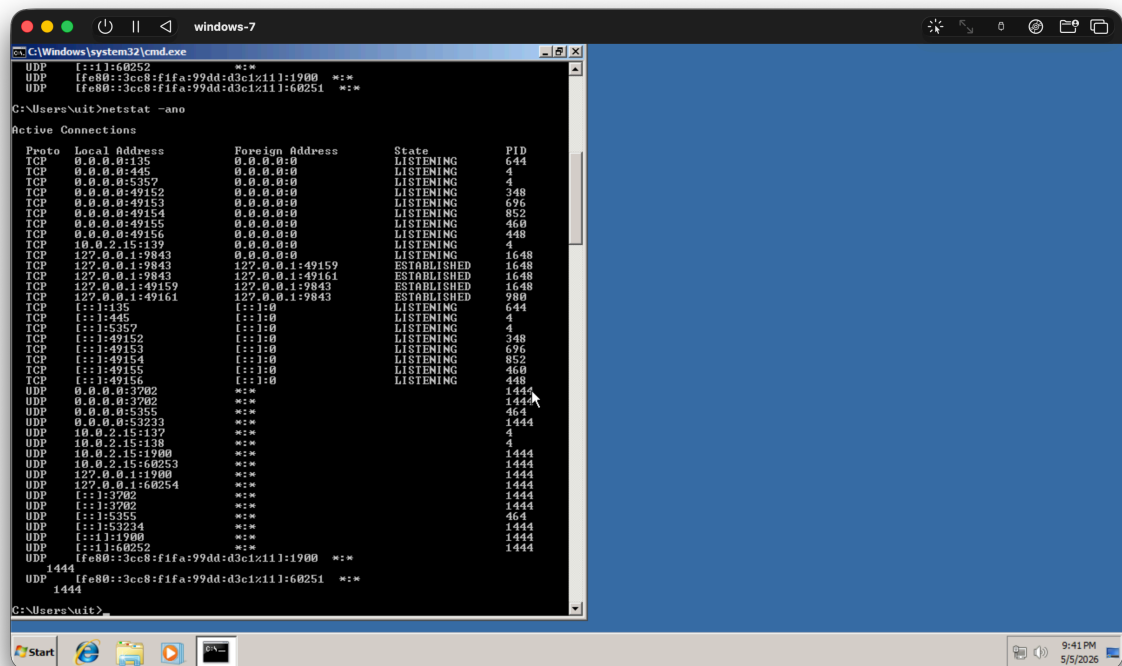
1.1.3. Ví Dụ

Ví dụ 1: `netstat -a`



Hình ảnh 1: netstat -a

Ví dụ 2: netstat -ano



Hình ảnh 2: netstat -ano

1.2. Fport

- Download: [Fport](#)

- Lưu ý:
 - Chương trình đã quá cũ, đây là một phiên bản tìm được trên GitHub
 - Có thể sử dụng `netsat` hoặc CurrPorts hoặc TCPViewe như các giải pháp thay thế.

1.2.1. Chức Năng

- Là một công cụ dòng lệnh cũ của Foundstone (hiện đã không thể tìm thấy trang chủ).
- Dùng để báo cáo tất cả các cổng TCP/IP và UDP đang mở.
- Ánh xạ (map) chúng trực tiếp tới các tiến trình/ứng dụng đang chạy.
- Nó giúp phát hiện nhanh các cổng đang bị mã độc (như Trojan hay Backdoor) mở để chờ các kết nối tới.

1.2.2. Cách Sử Dụng

- Chạy file `fport.exe` trong Command Prompt (yêu cầu quyền Admin).
- Màn hình sẽ trả về danh sách gồm Process Name, PID, Port và Protocol.

1.2.3. Ví Dụ

- Đây là một mô phỏng khi chạy chương trình.

```

1 C:\>fport
2 FPort v2.0 - TCP/IP Process to Port Mapper
3 Copyright 2000 by Foundstone, Inc.
4 http://nez
5
6 Pid      Process      Port  Proto Path
7 392      svchost      -> 135  TCP   C:\WINNT\system32\svchost.exe
8 8        System      -> 139  TCP
9 8        System      -> 445  TCP   C:\WINNT\system32\MSTask.exe
10 508      MSTask      -> 1025 TCP
11
12 392      svchost      -> 135  UDP   C:\WINNT\system32\svchost.exe
13 8        System      -> 137  UDP
14 8        System      -> 138  UDP
15 8        System      -> 445  UDP
16 224      lsass       -> 500  UDP   C:\WINNT\system32\lsass.exe
17 212      services    -> 1026 UDP   C:\WINNT\system32\services.exe
18
19 The program contains five (5) switches. The switches may be utilized using either a '/'
20 or a '-' preceding the switch. The switches are;
21
22 Usage:
23     /?      usage help
24     /p      sort by port
25     /a      sort by application
26     /i      sort by pid
27     /ap     sort by application path
28
29 For updates visit: www.foundstone.com

```

1.3. TCPView

- Download: [TCPView](#)

1.3.1. Chức Năng

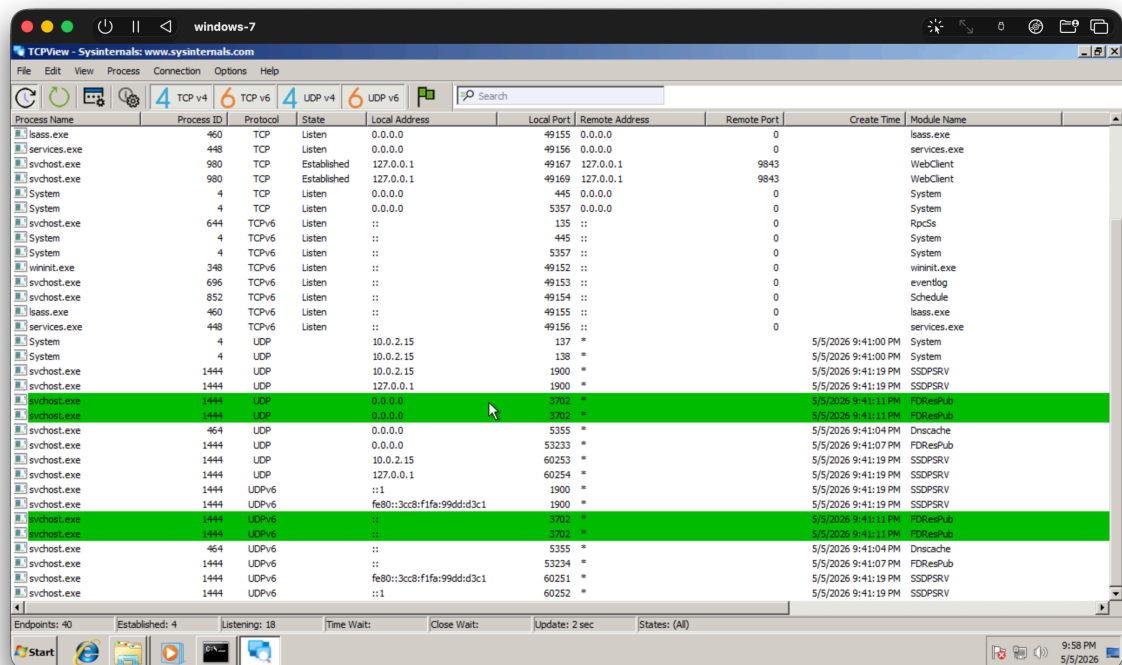
- Là công cụ đồ họa của bộ Sysinternals (Microsoft), rất khả tín.
- Cung cấp danh sách chi tiết và trực quan về tất cả các endpoint TCP và UDP trên hệ thống.
- Bao gồm địa chỉ local/remote và trạng thái hiện tại của kết nối.

1.3.2. Cách Sử Dụng

- Mở ứng dụng `Tcpview.exe`.
- Các kết nối mới tạo sẽ được tô màu xanh lá.
- Kết nối bị đóng tô màu đỏ.
- Nhấp chuột phải vào một kết nối khả nghi để chọn:
 - **Close Connection** (đóng kết nối)
 - **Kill Process** (buộc dừng tiến trình gây nhiễu).
- Có thể lựa chọn bật/tắt các giao thức:
 - TCP v4 / TCP v6
 - UDP v4 / UDP v6

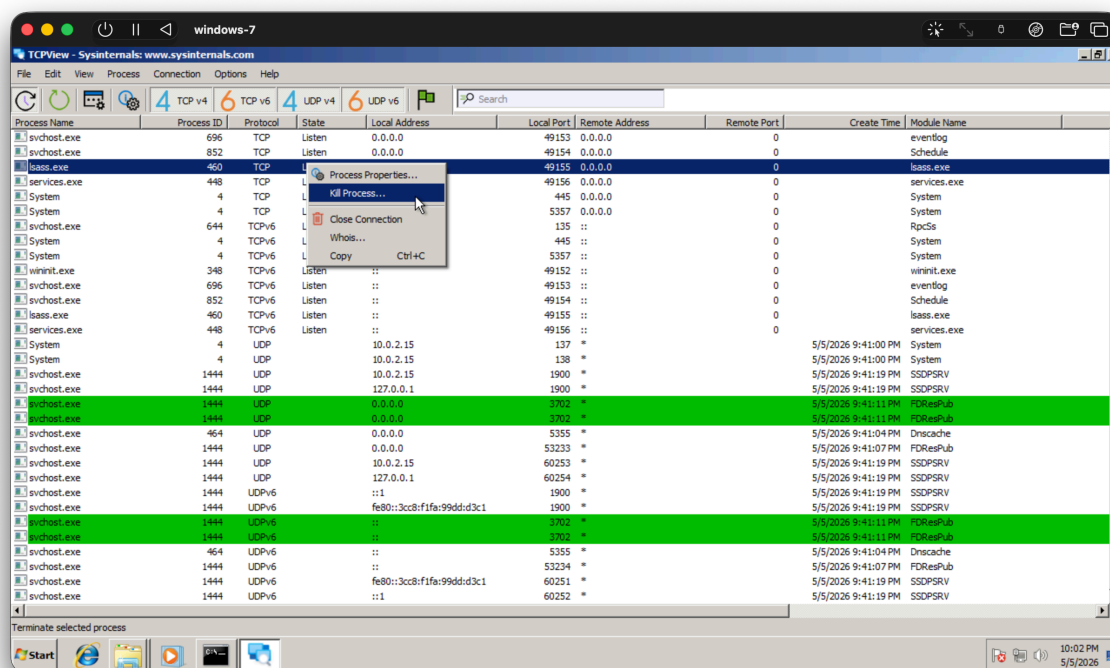
1.3.3. Ví Dụ

- Một giao diện rất đặc trưng và quen thuộc tương tự Process Explorer.



Hình ảnh 3: TCPView

- Có thể chọn **Close Connection** / **Kill Process** từ menu ngữ cảnh.



Hình ảnh 4: TCPView - Menu Ngữ Cảnh

1.4. CurrPorts Tool

- Download: [CurrPorts Tool at NirSoft](#).
- Là một trong loạt các tiện ích rất hữu dụng từ NirSoft.

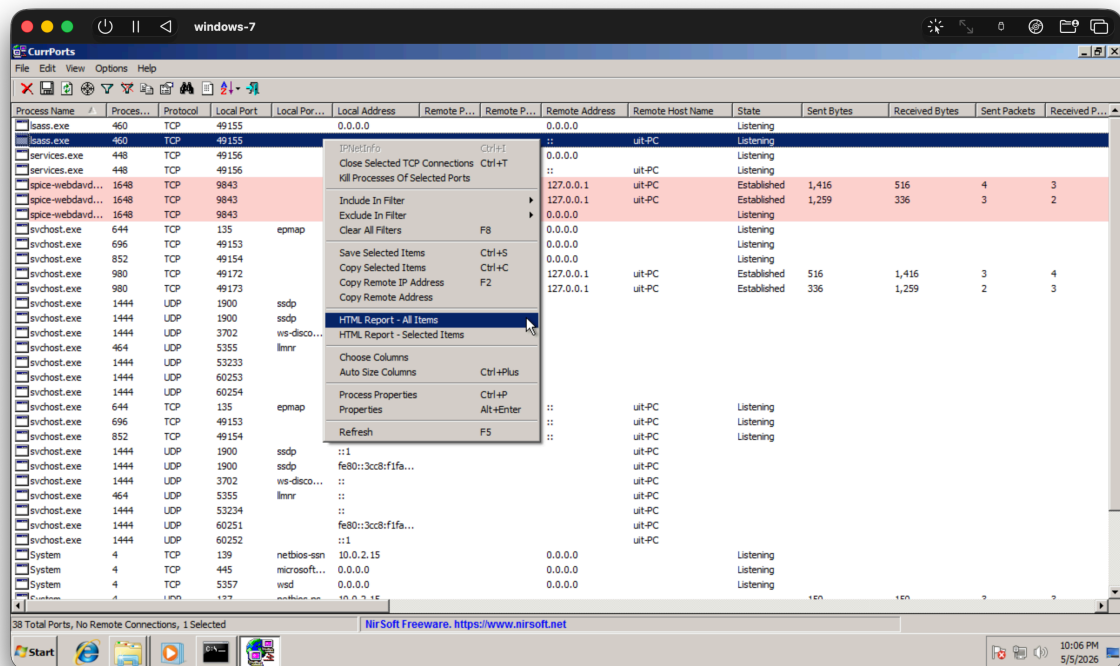
1.4.1. Chức Năng

- Tương tự TCPView
- Đây là một phần mềm/tiện ích giám sát mạng (của NirSoft).
- Hiển thị danh sách tất cả các cổng TCP/IP và UDP hiện đang mở trên máy tính.
- Cung cấp nhiều tùy chọn làm việc, đặc biệt cho phép trích xuất danh sách thành HTML trực quan.

1.4.2. Cách Sử Dụng

- Khởi chạy `cports.exe`.
- Ứng dụng sẽ liệt kê chi tiết tên tiến trình, đường dẫn file thực thi, và thông tin version của phần mềm đang mở cổng.
- Người dùng có thể bôi đen các tiến trình độc hại, nhấn nút **Kill Processes Of Selected Ports** để đóng chúng.
- Xuất báo cáo ra file HTML/XML để phân tích thêm.

1.4.3. Ví Dụ



Hình ảnh 5: CurrPorts Tool

1.5. Process Viewer (ay Process Explorer)

- Download: [Process Explorer](#)
- Đã được đề cập ở Bài Tập Thực Hành 4.

1.5.1. Chức Năng

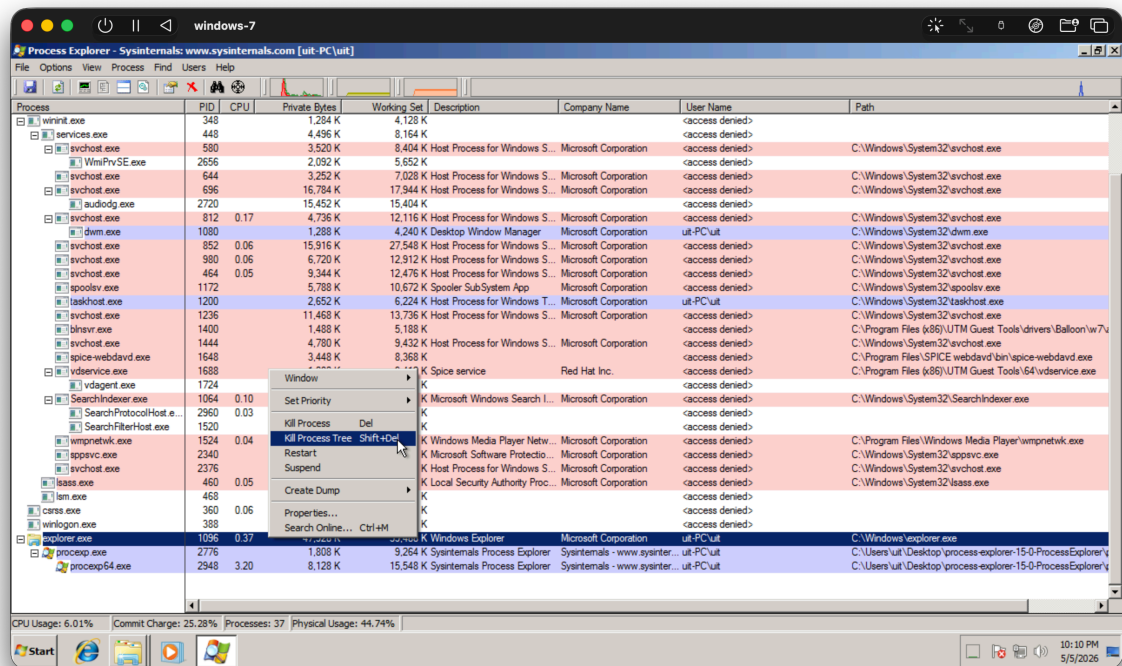
- Là công cụ giám sát tiến trình nâng cao.
- Cho phép theo dõi chi tiết:
 - ▶ Cấu trúc tiến trình (tiền trình cha/con).
 - ▶ Tài nguyên CPU/RAM sử dụng.
 - ▶ Các thư viện (DLL) đang được nạp vào bộ nhớ.

1.5.2. Cách Sử Dụng

- Mở ứng dụng để xem cây tiến trình (Process Tree).
- Nếu phát hiện một tiến trình lạ nguy trang thành file hệ thống (ví dụ `svchost.exe` nhưng chạy từ đường dẫn lạ):
 - ▶ Có thể click đúp vào để xem các luồng (threads)
 - ▶ Kiểm tra chữ ký số
 - ▶ Hoặc gửi trực tiếp mã băm (hash) của tiến trình đó lên VirusTotal để quét mã độc.

1.5.3. Ví Dụ

- Cây tiến trình (Process Tree) trực quan, giúp dễ dàng phát hiện tiến trình lạ.



Hình ảnh 6: Process Explorer

CÁC BIỆN PHÁP PHÒNG CHỐNG

Để phòng chống Trojan, Virus và Worm một cách hiệu quả, hệ thống cần thiết lập các rào cản từ mức độ con người đến mức độ kỹ thuật. Dưới đây là các biện pháp được sắp xếp theo **thứ tự ưu tiên từ cao đến thấp** về mức độ ảnh hưởng, và xét theo hướng từ con Người (quan trọng nhất) đến biện pháp kỹ thuật thuần túy.

2.1. Phòng Ngừa Ở Cấp Độ Người Dùng

- Nâng cao nhận thức người dùng nói chung.
- Phổ biến các quy trình, quy định về an toàn thông tin.
- Nhận biết và phản ứng với các kỹ thuật lừa đảo social engineering.
- Không mở file đính kèm lạ (như `.docm`, `.exe`) hoặc click vào link không rõ nguồn gốc trong email.
- Tuyệt đối không cài phần mềm crack, keygen hay dùng USB lạ.
- Tuân thủ quy trình bảo đảm an toàn dữ liệu của tổ chức: mật khẩu mạnh, cập nhật mật khẩu thường xuyên, vv...

2.2. Phòng Vệ Ở Cấp Độ Hệ Thống

- Tiếp theo là cấp độ hệ thống, nơi người dùng tương tác thường xuyên.
- Cập nhật bản vá lỗ hổng của ứng dụng và hệ điều hành.
- Quản lý quyền hạn cẩn trọng: quyền hạn tối thiểu; phân quyền tùy nhu cầu và vai trò công việc.
- Tắt các dịch vụ hệ thống không cần thiết.
- Triển khai các phần mềm diệt Virus mạnh mẽ.
- Triển khai các dịch vụ mã hóa dữ liệu cấp độ hệ thống.

2.3. Phòng Vệ Ở Cấp Độ Mạng

- Ngăn chặn các cổng và dịch vụ không chủ đích sử dụng từ hệ thống mạng/Fireware.
- Phát hiện và ngăn chặn các lưu lượng bất thường.
- Phân chia hệ thống mạng (segmentation) tùy vào khu vực và vai trò đặc trưng.
- Triển khai các hệ thống phát hiện và ngăn chặn (IDS/IPS).

2.4. Phòng Vệ Ở Cấp Độ Dữ Liệu

- Thực hiện chiến lược sao lưu 3-2-1 (3 bản sao, 2 phương tiện, 1 bản offline).

- Mã hóa và cô lập các dữ liệu quan trọng.
- Phân quyền truy cập dữ liệu hợp lý, có tính xác thực cao: ví dụ xác thực sinh học.

03 LOẠI MÃ ĐỘC TIÊU BIỂU GẦN ĐÂY

Một số thông tin về 3 loại mã độc (Malware) bao gồm các loại khác nhau (Trojan, Virus, Worm) đang gây ảnh hưởng lớn nhất trong không gian mạng hiện nay.

3.1. Trojan: Lumma Stealer (LummaC2)

- **Tên:** Lumma Stealer (còn gọi là LummaC2).
- **Nguồn gốc:**
 - Xuất hiện từ tháng 08/2022.
 - Được phát triển bởi cá nhân có bí danh “Shamel” (Lumma).
 - Vận hành theo mô hình Mã độc như một dịch vụ (Malware as a Service - MaaS) trên các diễn đàn tiếng Nga và Telegram.
- **Đặc điểm:**
 - Viết bằng ngôn ngữ C và ASM, nhẹ và nhanh.
 - Sử dụng kỹ thuật:
 - “ClickFix” (lừa người dùng copy-paste lệnh vào cửa sổ Run thông qua CAPTCHA giả).
 - “EtherHiding” (lưu trữ mã độc trên [blockchain Binance Smart Chain](#)) để lẩn tránh các hệ thống phòng thủ.
- **Phương thức phá hoại:**
 - Đánh cắp thông tin trình duyệt (mật khẩu, cookie phiên), ví tiền điện tử (MetaMask, Electrum) và cấu hình VPN.
 - Sử dụng kỹ thuật *process hollowing* để tiêm mã độc vào các tiến trình Windows hợp lệ như `explorer.exe` hoặc `msbuild.exe` để hoạt động ngầm.
- **Biện pháp phòng chống:**
 - Triển khai giải pháp *EDR* để phát hiện hành vi thực thi không tệp (*fileless*).
 - Đào tạo người dùng nhận biết kỹ thuật thao túng tâm lý CAPTCHA giả.
 - Thực hiện nguyên tắc đặc quyền tối thiểu (Least Privilege).
- **Nguồn tham khảo:**
 - [Microsoft - Microsoft Digital Defense Report 2025](#)
 - [Qualys - Unmasking Lumma Stealer: Analyzing Deceptive Tactics with Fake CAPTCHA](#)

- [Sophos - Lumma Stealer: coming and going](#)

3.2. Virus: Sality (Biến thể Đa hình 2024-2025)

- **Tên:** Virus Sality.
- **Nguồn gốc:**
 - Là dòng virus lâu đời (xuất hiện từ 2003).
 - Đã ghi nhận sự bùng phát mạnh mẽ trở lại trong năm 2024 và đầu năm 2025 với hạ tầng điều khiển (C2 - Command & Control) được nâng cấp.
- **Đặc điểm:**
 - Thuộc loại virus lây nhiễm tệp (*file infector*) đa hình (*polymorphic*) cực kỳ tinh vi.
 - Mã nguồn của nó liên tục thay đổi sau mỗi lần lây nhiễm để vượt qua các phần mềm diệt virus dựa trên chữ ký tĩnh.
- **Phương thức phá hoại:**
 - Tự động chèn mã độc vào các tệp thực thi `.exe` và `.dll` trên toàn bộ hệ thống.
 - Vô hiệu hóa Windows Defender, tường lửa và các công cụ bảo mật.
 - Biến máy tính nạn nhân thành một phần của botnet để đào tiền ảo hoặc phát tán thư rác.
- **Biện pháp phòng chống:**
 - Sử dụng phần mềm diệt virus dựa trên phân tích hành vi (*Behavior-based*) thay vì chỉ dựa vào chữ ký.
 - Quét hệ thống định kỳ bằng các công cụ chuyên dụng có khả năng khử nhiễm (*disinfection*) tệp tin và bảo vệ tính toàn vẹn của hệ thống.
- **Nguồn tham khảo:**
 - [Recorded Future - H1 2025 Malware and Vulnerability Trends](#)
 - [ESET - Threat Report H2 2025](#)

3.3. Worm: Morris II (Sâu AI)

- **Tên:** Morris II.
- **Nguồn gốc:**
 - Được công bố vào đầu năm 2024 bởi nhóm nghiên cứu từ *Cornell Tech*, *Technion* và *Intuit* như một minh chứng về lỗ hổng của các hệ thống AI hiện đại.
- **Đặc điểm:**
 - Sâu máy tính “không nhấp chuột” (*zero-click*) đầu tiên nhắm vào các hệ sinh thái Trí Tuệ Nhân Tạo Tạo Sinh (GenAI) như GPT-4 và Gemini.
 - Nó sử dụng các “câu lệnh tự sao chép đối nghịch” (*Adversarial Self-Replicating Prompts*) để thao túng phản hồi của AI.
- **Phương thức phá hoại:**
 - Thông qua việc thao túng phản hồi của các tác nhân AI.

- Khi trợ lý email AI xử lý một thông điệp nhiễm sâu, nó bị buộc phải trích xuất dữ liệu nhạy cảm (PII - Personal Identity Information, số thẻ tín dụng).
- Và tự động tạo ra các email mới chứa chính mã độc của sâu để gửi đến các người dùng khác.
- Tạo ra chuỗi lây nhiễm bùng nổ trong mạng lưới AI.
- **Biện pháp phòng chống:**
 - Thực hiện kiểm tra tính hợp lệ của dữ liệu đầu vào/đầu ra (*Input/Output validation*).
 - Cách ly các tác nhân AI (*AI agents*) trong môi trường riêng biệt (*Segmentation*);
 - Và áp dụng xác thực API nghiêm ngặt cùng giám sát bất thường về tần suất truy vấn.
- **Nguồn tham khảo:**
 - [arXiv - Here Comes The AI Worm: Unleashing Zero-click Worms that Target GenAI-Powered Applications](#)
 - [IBM - Morris II Self-Replicating Malware in GenAI Email Assistants](#)
 - [SentinelOne - AI Worms Explained: Adaptive Malware Threats](#)

3.4. Phụ Lục: Giải Thích Thuật Ngữ Kỹ Thuật

- **Process Hollowing:**
 - Kỹ thuật tiêm mã độc bằng cách tạo ra một tiến trình hợp lệ ở trạng thái tạm dừng, sau đó xóa bỏ phần mã gốc trong bộ nhớ RAM và thay thế bằng mã độc hại trước khi cho tiến trình chạy tiếp.
- **EDR (Endpoint Detection and Response):**
 - Giải pháp an ninh tập trung vào việc giám sát và phản hồi các mối đe dọa tại điểm cuối (máy tính, máy chủ) dựa trên phân tích hành vi thời gian thực.
- **Fileless Malware:**
 - Mã độc không tệp, hoạt động trực tiếp trong RAM và sử dụng các công cụ hệ thống hợp lệ để thực thi, không để lại dấu vết trên ổ cứng.
- **MaaS (Malware-as-a-Service):**
 - Mô hình kinh doanh tội phạm mạng, trong đó kẻ phát triển mã độc cho thuê hạ tầng và công cụ tấn công cho các đối tượng khác để thu phí.
- **File Infector:**
 - Loại mã độc ký sinh bằng cách đính kèm mã độc vào các tệp thực thi hợp lệ và lan truyền khi người dùng chạy các tệp đó.
- **Polymorphic (Đa hình):**
 - Khả năng tự thay đổi hình dạng mã (mã hóa hoặc làm rối) sau mỗi lần lây nhiễm nhưng vẫn giữ nguyên chức năng độc hại, nhằm lẫn tránh sự phát hiện của chữ ký số tĩnh.
- **Zero-click:**

- Loại tấn công không cần bất kỳ sự tương tác nào của người dùng (như nhấp link hay mở tệp) để mã độc được thực thi.
- **Adversarial Self-Replicating Prompts:**
 - Các câu lệnh độc hại được thiết kế để đánh lừa mô hình AI, khiến nó tạo ra kết quả bao gồm chính câu lệnh đó (kết quả bình thường) cùng với hành vi phá hoại (kết quả độc hại).
- **C2 (Command & Control):**
 - Máy chủ điều khiển do tin tặc vận hành dùng để gửi lệnh và nhận dữ liệu đánh cắp được từ máy nạn nhân.

Thông Tin Về Báo Cáo Đây

A.1 Mã Nguồn Báo Cáo

- Miêu tả: Báo cáo này được xây dựng từ mã nguồn [Typst](#), với nội dung chính được chuẩn bị từ Markdown.
- Lưu trữ tại: nhánh [IE105-ch05](#) của repo [sam-uit/typst-report-template](#)

A.2 Mã Nguồn Nội Dung Chính

- Miêu tả: Được chuẩn bị với Markdown, trong kho của [Obsidian](#).
- Lưu trữ tại: [uit/courses/IE105/assignments](#)

Tài Liệu Tham Khảo
